

Vulnerability Management Report

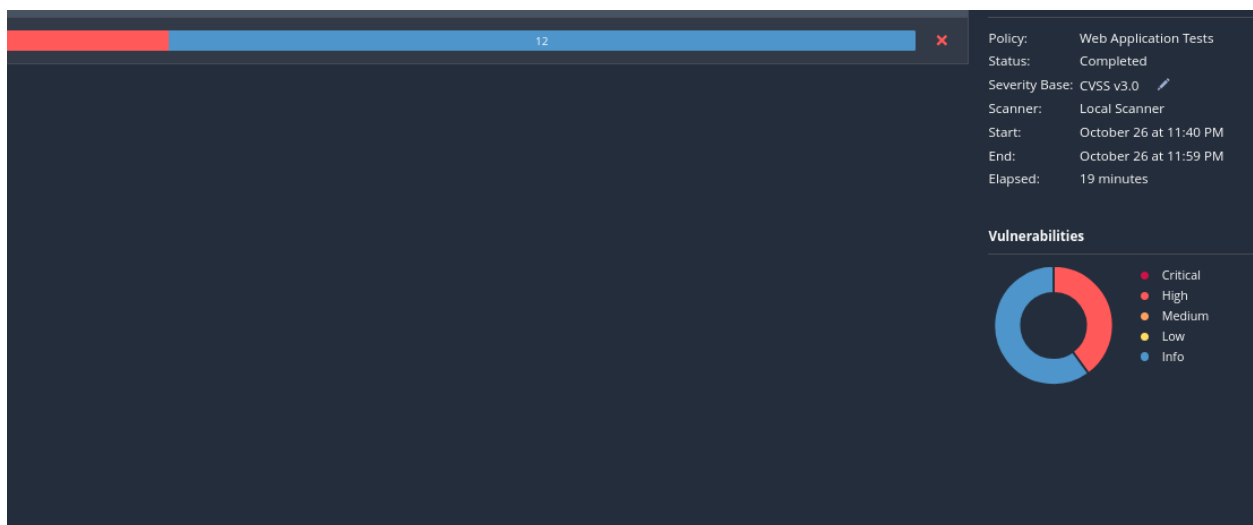
By

ALI CHINASA

On 24th, October 2025.

Executive Summary

A vulnerability assessment was conducted within a controlled SOC lab to identify weaknesses in the internal network environment. Using Nessus Essentials, the analysis revealed medium to high-severity vulnerabilities linked to outdated versions of Nginx and OpenSSL. These vulnerabilities pose potential risks to service availability, confidentiality, and overall system integrity. This report summarizes the findings, associated risks, challenges encountered, and practical recommendations to improve security posture.



Environment Description

The lab environment consisted of a Kali Linux virtual machine used as the scanner and an Ubuntu virtual machine as the target system. The Ubuntu VM hosted intentionally outdated

services **Nginx 1.15.5** and **OpenSSL 1.0.2** to simulate real-world vulnerabilities. Nessus Essentials was installed and configured on Kali Linux to perform a network vulnerability scan targeting the Ubuntu host **IP: 192.168.75.4**.

Discovered Vulnerabilities

Nginx Information Disclosure

- CVE ID: CVE-2019-20372
- CVSS v3.0 Base Score: 5.3 (Medium)
- Exploit Status: Exploit available

Description: This vulnerability allows attackers to gain information about the Nginx version through HTTP headers. Such version exposure can help attackers identify specific exploits for that version, aiding reconnaissance and targeted attacks.

CVE-2019-20372 Detail

MODIFIED

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

NGINX before 1.17.7, with certain error_page configurations, allows HTTP request smuggling, as demonstrated by the ability of an attacker to read unauthorized web pages in environments where NGINX is being fronted by a load balancer.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: **5.3 MEDIUM**

Vector:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

nginx-ssh-weakness / Plugin #134220
[Back to Vulnerability Group](#)

Vulnerabilities 25

MEDIUM nginx < 1.17.7 Information Disclosure

Description
According to its Server response header, the installed version of nginx is prior to 1.17.7. It is, therefore, affected by an information disclosure vulnerability.

Solution
Upgrade to nginx version 1.17.7 or later.

See Also
<http://www.nessus.org/76902623>

Output

```
URL:      : http://192.168.75.4:8080/
Installed version : 1.15.5
Fixed version    : 1.17.7
```

To see debug logs, please visit individual host

Port **Hosts**

Port	Hosts
8080/tcp/www	192.168.75.4

Risk Information
Vulnerability Priority Rating (VPR): 2.2
Exploit Prediction Scoring System (EPSS): 0.6767
Risk Factor: Medium
CVSS v3.0 Base Score: 5.3
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
CVSS v3.0 Temporal Vector: CVSS:3.0/E:P/RL:O/RC:C
CVSS v3.0 Temporal Score: 4.8
CVSS v2.0 Base Score: 4.3
CVSS v2.0 Temporal Score: 3.4
CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N
CVSS v2.0 Temporal Vector: CVSS2#E:POC/RL:OF/RC:C
IAVM Severity: I
Vulnerability Information
CPE: cpe:/a:nginx:nginx
Exploit Available: true
Exploit Ease: Exploits are available
Patch Pub Date: December 24, 2019
Vulnerability Pub Date: December 24, 2019
Reference Information
IAVB: 2020-B-0013-S
CVE: CVE-2019-20372

OpenSSL CMS Decryption Out-of-Bounds Access

- CVE IDs: CVE-2025-9230 and CVE-2025-9232
- CVSS v3.0 Base Score: 7.5 (High)
- Exploit Status: No known public exploit available

Description: These vulnerabilities can cause out-of-bounds read/write conditions during CMS decryption, potentially leading to denial of service or memory corruption. While exploitation is complex, successful attacks can disrupt service operations or expose sensitive data.

CVE-2025-9230 Detail

AWAITING ANALYSIS

This CVE record has been marked for NVD enrichment efforts.

Description

Issue summary: An application trying to decrypt CMS messages encrypted using password based encryption can trigger an out-of-bounds read and write. Impact summary: This out-of-bounds read may trigger a crash which leads to Denial of Service for an application. The out-of-bounds write can cause a memory corruption which can have various consequences including a Denial of Service or Execution of attacker-supplied code. Although the consequences of a successful exploit of this vulnerability could be severe, the probability that the attacker would be able to perform it is low. Besides, password based (PWRI) encryption support in CMS messages is very rarely used. For that reason the issue was assessed as Moderate severity according to our Security Policy. The FIPS modules in 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this issue, as the CMS implementation is outside the OpenSSL FIPS module boundary.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other

Plugin Details	Risk Information
Severity: High ID: 266297 Version: 1.2 Type: combined Family: Web Servers Published: September 30, 2025 Modified: October 3, 2025	Vulnerability Priority Rating (VPR): 5.1 Exploit Prediction Scoring System (EPSS): 0.0003 Risk Factor: Medium CVSS v3.0 Base Score: 7.5 CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RC:C CVSS v3.0 Temporal Score: 6.5 CVSS v2.0 Base Score: 4.3 CVSS v2.0 Temporal Score: 3.2 CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:N/I:N/A:P CVSS v2.0 Temporal Vector: CVSS2#E:U/RL:OF/RC:C IAVM Severity: II
VPR Key Drivers	Vulnerability Information
Threat Recency: 7 to 30 days Threat Intensity: High Exploit Code Maturity: Unproven Age of Vuln: 7 - 30 days Product Coverage: Low CVSSV3 Impact Score: 3.6 Threat Sources: Social Media	CPE: cpe:/a:openssl:openssl Exploit Available: false Exploit Ease: No known exploits are available Patch Pub Date: September 30, 2025 Vulnerability Pub Date: September 30, 2025
	Reference Information
	IAVA: 2025-A-0716 CVE: CVE-2025-9230, CVE-2025-9232

Risk Summary

CVE-2019-20372 (Nginx): Medium risk due to information leakage that can support further attacks.

CVE-2025-9230 / CVE-2025-9232 (OpenSSL): High risk because of potential service disruption and data exposure, despite low exploit availability.

Together, these vulnerabilities reduce the overall resilience of the system and highlight the importance of consistent patch management.

Recommendations

- Upgrade Nginx to version 1.17.7 or higher to eliminate version disclosure flaws.
- Update OpenSSL to the latest stable release (1.0.2m or later).
- Regularly apply vendor patches and maintain a schedule for security updates.
- Implement version obfuscation in Nginx configuration to prevent information exposure.
- Perform periodic vulnerability scans and monitor software end-of-life announcements to reduce exposure.

Challenges and Resolutions

While configuring SSH, the arcfour cipher was flagged as outdated by both Ubuntu and Kali. To maintain compatibility and continue testing, the 3des-cbc cipher was enabled instead. And also I had issue with installation of Nessus plugins.